# Unit – IV

# Cloud Security Risks

# Agenda

| |
|---|
| Security in an interconnected world, cloud security risks |
| Attacks in a cloud environment, top threats |
| Security, a major concern for cloud users |
| Privacy |
| Trust |
| Operating systems security |
| Virtual machine security |
| Security of virtualization |
| Security risks posed by shared images |
| Security risks posed by a management OS |

# Computer security in the new millennium

Malware can rapidly spread acros
crossing national borders and cau
infections.

Growing dependence on informat
infrastructure makes computer ar
communication security increasir

Critical national infrastructure is v
to exploitation through security fla

Cyberwarfare refers to nation-stat
aimed at penetrating another cou
networks to cause damage or disr

# Cloud security

- Cloud environments are highly attractive targets fo
actors and criminal organizations.
- Security and privacy remain major concerns for bo
and prospective cloud users.
- Outsourcing to the cloud introduces new risks aro
protection and trust.
- Global standards, regulations, and laws for cloud
are still lacking.
- International regulatory frameworks are needed to
data centers across countries.
- Service Level Agreements (SLAs) provide limited le
protection, leaving users vulnerable to uncontrolla

# Cloud security risks

**Amplified traditional threats**: Cloud scale and
base increase the impact of conventional attac

**New threats**: Multi-tenancy and VMM vulnerab
create fresh attack channels; attacker paths ha
trace.

**Authentication & authorization gaps**: Individu
procedures don't adequately extend to enterpr
contexts.

**Third-party control risks**: Limited transparenc
reduced user control raise significant security c

**Service availability issues**: Failures, outages,
catastrophic events can disrupt cloud services
periods.

# Attacks in a cloud computing environment

Three main actors: **user, se**
**cloud infrastructure.**

**User attacks:**

By serv
spoofin
attacks

By clou
attacks
spoofe

**Service attacks:**

By user
injectio

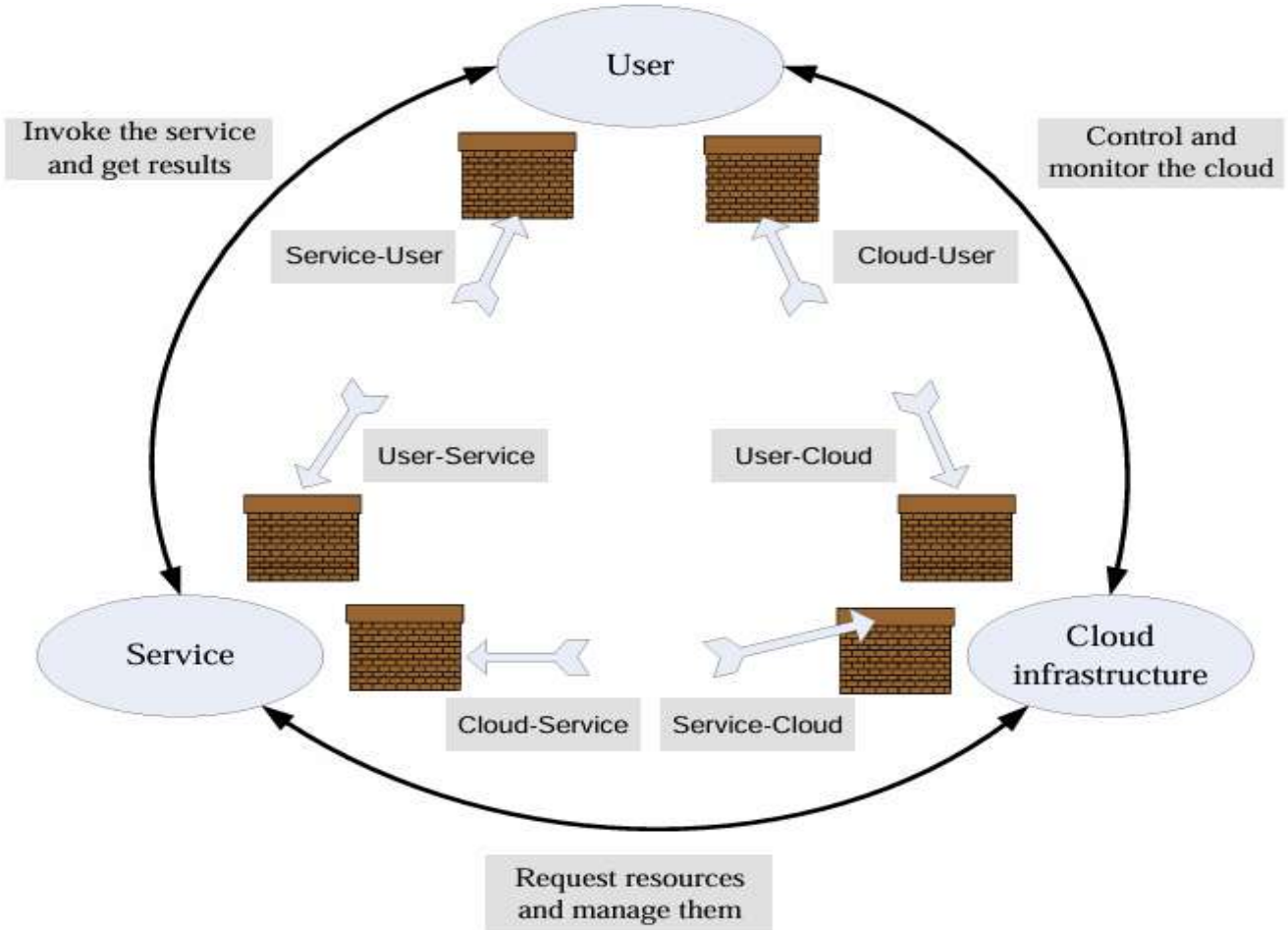
By clou
resourc
abuse,
operati

**Cloud infrastructure attacks:**

By user
control

By serv
request

# Attacks in a cloud computing environm




Surfaces of attacks in a cloud computing environment.

# Top threats to cloud computing

**Abusive use of cloud**: Cloud resourc
be exploited to conduct malicious or
activities.

**Insecure APIs**: Weak API security exp
users during authentication, access c
monitoring, and runtime operations.

**Malicious insiders**: Lack of transpare
provider hiring practices creates insid
threat risks.

**Shared technology risks**: Multi-tena
shared infrastructure increase vulner

# Top threats to cloud computing

**Account hijacking:** Unautho
access to user accounts
compromises data and servi

**Data loss or leakage:** Failur
replication or storage can ca
permanent loss of sensitive

**Unknown risk profile:** Users
underestimate or be unawar
the full risks of cloud compu

# Auditability of cloud activities

**Auditability challenge**: Limited transparency makes
auditing cloud activities difficult.

**Mandatory guidelines**: U.S. Government agencies m
follow NIST auditing standards.

**Key frameworks**:

Federal Information Proc
Standard (FIPS).

Federal Information Secu
Management Act (FISMA

# Security - the top concern for cloud user

**UNAUTHORIZED ACCESS & DATA THEFT** ARE THE TOP CONCERNS FOR CLOUD USERS.

**DATA IN STORAGE** IS HIGHLY VULNERABLE DUE TO LONG RETENTION PERIODS.

**PROCESSING THREATS** CAN ARISE FROM FLAWS IN VMMS, ROGUE VMS, OR VMBRS.

**INSIDER**
EMPLOYEES
PROVIDE
COMPR

# Security - the top concern for cloud user

**LACK OF STANDARDIZATION** REMAINS A SIGNIFICANT CHALLENGE FOR CLOUD SECURITY.

**LEGAL FRAMEWORK CONCERNS**: USERS WORRY ABOUT ENFORCEMENT OF CLOUD SECURITY LAWS.

**MULTI-TENANCY RISKS**: ROOT CAUSE OF MANY THREATS, THOUGH IT IMPROVES SERVER UTILIZATION AND REDUCES COSTS.

**THREATS VAR**
SPECIFIC CLO

# Legal protection of cloud users

- The contract between the user and the Cloud Service Provider (CSP) shoul
  out explicitly:
  - CSP obligations to handle securely sensitive information and its obligat
    comply to privacy laws.
  - CSP liabilities for mishandling sensitive information.
  - CSP liabilities for data loss.
  - The rules governing ownership of the data.
  - The geographical regions where information and backups can be stored

# Privacy

- **Definition**: Privacy is the right to keep personal or information undisclosed.
- **Legal protection**: Privacy is safeguarded by law, th certain laws may impose limits.
- **Key aspects**: Lack of user control, unauthorized s use, data proliferation, and dynamic provisioning.
- **Digital age challenges**: Legislators face new threa identity theft from stolen or misused shared data.
- **Cloud context**: Privacy concerns vary across diffe delivery models and depend on specific usage sce

# Federal Trading Commission Rules

**Notice**: Websites must clearly inform co
about what data is collected, how it is us
shared, and secured.

**Choice**: Consumers should be given opt
how their personal information is used, b
internally and externally.

**Access**: Consumers must have reasona
access to review, correct, or delete their
information collected by the site.

**Security**: Websites are required to take
appropriate measures to safeguard the p
information they collect.

# Privacy Impact Assessment (PIA)

**Need for tools**: Identifying privacy issues in informatio
requires specialized tools.

**Lack of standards**: No international standards exist, t
countries and organizations mandate Privacy Impact A
(PIA) reports.

**Proposed solution**: A SaaS-based PIA tool is suggeste

**Key features**:

- Users complete a questionnaire to provide input.
- Knowledge base (KB) maintained by domain experts supports the s
- Templates generate additional questions and structure the PIA repo
- Expert system applies rules, prioritizes them, and executes based o
  facts.

# Trust

- **Definition**: Trust is assured reliance on the character, ability, strength, or truth of an en
- **Role of trust**: Enables cooperation, adapti organizations, reduces conflict, lowers tran costs, and supports crisis response.
- **Conditions for trust**:
  - Risk → trust is only relevant when there possibility of loss.
  - Interdependence → entities must rely o other to achieve goals.
- **Phases of trust**:
  - Building – trust is established.
  - Stability – trust is maintained.
  - Dissolution – trust declines or is lost.
- **Fragility of trust**: Difficult to build, but eas

# Internet Trust

**Internet trust limitations:** Lacks traditional di
character, relationship, and institutional conte

**Anonymity factor:** Individuals can conceal ide
cues normally used to judge trustworthiness.

**Importance of identity:** Trust relies on past in
anonymity undermines accountability and fos

**Opacity challenge:** Personal characteristics a
identity are difficult to verify in online transacti

**Uncertainty of roles:** No assurance that entiti
understand or fulfill the responsibilities they a

# How to determine trust

- **Policies**:
  - Define conditions required to establish trust.
  - Rely on credential verification issued by trusted authorities to validate entity q

- **Reputation**:
  - Built over time through consistent interactions or observations.
  - Recommendations reflect trust decisions made by others, filtered through the assessor's perspective.

- **Computer science context**:
  - Trust is the measurable belief that one party (A) can rely on another party (B) to dependably for a specified period within a defined service context (X).

# Operating system security

**OS security role**: Protects applications from atta
unauthorized access, code tampering, and spoo

**Mandatory OS security elements**:

- **Access control** → regulates access to system objects.
- **Authentication** → verifies the identity of principals.
- **Cryptographic policies** → safeguard data through encrypt

**Commercial OS limitation**: Typically lack multi-
offering only privileged vs. unprivileged domains.

**Trusted paths mechanisms**: Ensure secure use
trusted software; without them, malicious softwa
impersonate trusted applications.

**Examples of trusted paths**: Login authenticatio
changes, and server-client authentication.

# Closed-box versus open-box platforms

**Closed-box platforms** (e.g., phones, game co
use embedded cryptographic keys to prove ide
authenticate software.

**Open-box platforms** (commodity operating sy
such facilities, offering lower assurance.

**Complexity risk**: Commodity OSs have millio
code, making them vulnerable to diverse malic

**Weak authentication**: Limited mechanisms fo
to verify each other or establish trusted paths

**Poor isolation**: Compromise of one applicatio
the entire platform, reducing overall security to
application's level.

# Virtual machine security

**Hybrid/hosted VMs**: Expose the system to
of the host operating system.

**Traditional VMs**:

- VMM (Virtual Machine Monitor) enforces stricter isola
than processes in a standard OS.
- VMM controls privileged operations, memory, disk, ar
- VMMs are simpler and better structured than OSs, ma
resilient to attacks.

**Key challenge**: VMM only sees raw system
security services operate at higher logical le
files).

**Trusted Computing Base (TCB)**: Essential
if compromised, the entire system's securit
undermined.

# VMM-based threats

**Resource starvation & denial of service:**

Caused by misconfigured resource limits for VMs.

Rogue VMs bypassing limits set in the Virtual Machi

**VM side-channel attacks:**

Result from poor isolation of inter-VM traffic due to r networks.

Packet inspection devices unable to handle high-sp video).

Use of insecure VM images, such as guest OS witho

**Buffer overflow attacks:** Remain a critical vulnerab environments.

# VM-based threats

**Rogue or insecure VM deploy**
Unauthorized users may create
instances or perform unauthor
administrative actions.

**Probable cause:** Improper con
access controls for VM tasks (c
suspension, re-activation).

**Insecure/tampered VM image**
from compromised images in t
repository.

**Probable causes:**

L
V
A
v
s
in

# Security of virtualization

**VM state capture**: Entire OS state can b
and shared as a file.

**IaaS support**: Enables users to select c
and run applications in the cloud.

**Reliability**: OS and applications can be
switched to hot standby for continuity.

**Intrusion prevention/detection**: Clones
activity patterns, detect intrusions, and

**Software testing efficiency**: Virtualizati
need for numerous dedicated systems b
OS instances to share fewer physical ma

# Advantages of virtualization

**Load balancing**: A Virtual Machine M
(VMM) can migrate OS and applicatio
another server when load exceeds a t

**Power efficiency**: Workloads from lig
servers can be consolidated, allowing
servers to be turned off or put in stan

**Security advantage at VMM layer:**

- Secure logging and intrusion protection imple
VMM level cannot be disabled or altered by in
- At the OS level, intrusion detection and loggin
vulnerable to tampering.
- VMM-based logging focuses on critical events
effective post-attack analysis.

# Undesirable effects of virtualization

**System management challenges**: Virtual machine
to create, leading to uncontrolled growth.

**Resource limits**: Physical systems are constrained
energy, and human support, but VM creation is only
storage capacity.

**Heterogeneity issues**: Unlike traditional environm
uniform system software, virtual environments hos
versions and patch levels, increasing complexity fo

**Security implications**:

- Traditional software lifecycle assumes linear progression for
- Virtual execution follows a tree-like model, with multiple VM
differently, complicating updates and security maintenance.

# Implications of virtualization on secu

**Persistent infections**: Dormant infected VMs can reactivate later, sprea
repeatedly.

**Steady state challenge**: Unlike traditional environments where patching
stable secure state, virtual environments may never reach such stability
control.

**Rollback vulnerability**: Saving and restoring complete VM states introdu
malicious events recorded in memory can resurface after rollback.

**Time-sensitive data risk**: Virtualization undermines the principle of min
retention of sensitive data, increasing exposure to attacks.

# Security risks posed by shared imag

**Image sharing importance:** Critical for the IaaS cloud delivery model, e
select and run applications via AWS AMIs (Quick Start or Community AM

**Data exposure risks:** Many analyzed images allowed recovery of sensiti
(files, credentials, private keys) using standard tools.

**Audit findings:**

98% of Windows AMIs contained c
58% of Linux AMIs contained critic

**Security risks associated with shared images:**

Presence of backdoors and leftove
Unsolicited connections.
Embedded malware.

# Security risks posed by a management OS

- **Hypervisor size**: Virtual Machine Monitors (VMMs) are much s
operating systems; e.g., Xen VMM has ~60,000 lines of code.

- **Trusted Computing Base (TCB)**: In cloud environments, the TCB i
the hypervisor and the management OS.

- **Management OS role**: Provides administrative tools, live migra
drivers, and emulators.

**Xen architecture**:

- Management OS runs in Dom0 and oversees creation of user domai
- Steps in building a new VM:
  - Allocate memory in Dom0 and load guest OS kernel from storage
  - Allocate memory for the VM and use foreign mapping to load the
  - Set up initial page tables for the VM.
  - Release foreign mapping, configure virtual CPU registers, and lau

# Security risks posed by a management OS

**Trusted Computing Base (TCB):** In a Xen-based
the TCB consists of the hardware, the Xen hyperv
management operating system running in Dom0

**Management OS (Dom0):** Provides critical funct
administrative tools, live migration, device driver
emulators.

**Guest OS (DomU):** Runs user applications and c
isolated domains managed by Dom0.

**Separation of roles:**

- Dom0 handles system-level management and resource allo
- DomU hosts user workloads, ensuring isolation and controll
  Xen.

# Possible actions of a malicious Dom0

**DomU creation risks**:

- Dom0 may refuse to start a new VM.
- Kernel of the guest OS could be modifie
  third-party monitoring/control.
- Integrity compromised by incorrect pag
  virtual CPU register setup.
- Foreign mapping may not be released, all
  to access VM memory during execution.

**Run-time risks**:

- Dom0 exposes abstract devices via
  (frontend in DomU, backend in Dom0).
- Communication between DomU and Do
  encrypted to mitigate risks.
- TLS alone cannot prevent Dom0 fror
  cryptographic keys from OS or applicatio
  DomU.

# A major weakness of Xen

**XenStore role:** Maintains the co
state of the system in a Xen-base
environment.

**Security risk:** A malicious VM ca
other VMs from accessing XenSt
disrupting operations.

**Memory access threat:** Malicio
may gain unauthorized access to
memory of a DomU, underminin
isolation and system integrity.

# How to deal with run-time vulnerability of Dom0

**Secure run-time requirement:** Hy
between an untrusted Dom0 and a
DomU must be intercepted and co

**New hypercalls needed:**

**Virtual CPU privacy & integrity:**

- Intercept hypercalls when Dom0 saves VN
- Encrypt virtual CPU registers before storag
- Decrypt and perform integrity checks whe DomU.

# How to deal with run-time vulnerability of Dom0

## New hypercalls needed:

### Virtual memory privacy & integ

- Intercept page table update hypercalls.
- Encrypt VM memory pages so Dom0 onl encrypted data.
- Hypervisor computes hashes of all men before saving.
- Address translation ensures restored Do to new memory regions.

### Freshness guarantee:

- Add version numbers to hashes of CPU states.
- Prevent rollback attacks and ensure sta consistency.

# Thank You